

Security+ 4.5 · Web Filtering

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.5 — Web Filtering (10:00)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Web filtering involves URL scanning by category, content filtering, HTTP proxy (intermediary), DNS blocklisting (blocks at resolution), reputation-based filtering, and bot detection.

High-Yield Core Concepts Tested on Exam

- DNS blocklist blocks before the browser opens the site
- Web proxy intermediates HTTP/S and can inspect traffic
- URL scanning categorizes websites to enforce policies
- Content filtering blocks specific types of content
- Reputation-based filtering uses threat intelligence to block malicious sites
- Bot detection identifies automated traffic

Exam Tips & Classic Scenarios

- If the question mentions 'blocks domains at the DNS level', the answer is DNS filtering
- DNS filtering is efficient because it blocks before a connection is made

Typical Exam Scenario: A company blocks access to phishing sites by preventing DNS resolution of known malicious domains. This is DNS filtering.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.5 — Web Filtering)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An attacker tests leaked passwords from one site on MULTIPLE other sites (password reuse):

- A)** Credential stuffing
- B)** Pure brute force
- C)** Rainbow table
- D)** Vishing

2. An attacker uses RFID to clone employee badges and access restricted areas. What type of physical attack is this?

- A) Tailgating**
- B) Shoulder surfing**
- C) Credential cloning**
- D) Dumpster diving**

3. Corporate scenario (Web Filtering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: 'DNS blocklist: blocks BEFORE the browser opens the site'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Implement the corresponding solution: DNS blocklist: blocks BEFORE the browser opens the site...**
- D) Allow shared access among administrators with generic credentials**

4. Corporate scenario (Web Filtering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: 'Web proxy: mediates HTTP/S and can inspect'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Implement the corresponding solution: Web proxy: mediates HTTP/S and can inspect...**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators with generic credentials**

5. Corporate scenario (Web Filtering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: '"blocks domains at the DNS level'=DNS filtering'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Implement the corresponding solution: 'blocks domains at the DNS level'=DNS filtering...**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators using generic credentials**

6. Corporate scenario (Web Filtering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: 'company blocks access to phishing sites via DNS'=DNS filtering.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'company blocks access to phishing sites via DNS'=DNS filtering....
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Web Filtering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: 'DNS blocklist: blocks BEFORE the browser opens the site'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: DNS blocklist: blocks BEFORE the browser opens the site.

8. Corporate scenario (Web Filtering): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 4.5) exam, an analyst evaluates the following technical requirement: 'Web proxy: mediates HTTP/S and can inspect'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Web proxy: mediates HTTP/S and can inspect...

9. Corporate scenario (Web Filtering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: "blocks domains at the DNS level'=DNS filtering'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'blocks domains at the DNS level'=DNS filtering...

10. Corporate scenario (Web Filtering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: "company blocks access to phishing sites via DNS'=DNS filtering.'. What is the best recommendation or classification of applicable control?

- A)** Implement the corresponding solution: 'company blocks access to phishing sites via DNS'=DNS filtering...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Credential stuffing.

✓ **Why it's correct:** Credential stuffing is a cyberattack in which the attacker uses lists of credentials (username and password pairs) obtained from data breaches on one site to attempt authentication on multiple other sites, exploiting the common practice of password reuse. The attack is automated and relies on large volumes of leaked credentials. It differs from pure brute force because it does not attempt to guess passwords but uses already known combinations. It is a topic in the Threats, Vulnerabilities, and Mitigations domain of Security+ (SY0-701), objective 2.4, which covers attack techniques.

✗ **Why the others are wrong:**

- *Pure brute force:* Pure brute force is an attack method that exhaustively tries all possible character combinations until it finds the correct password. In credential stuffing, the attacker does not test random combinations; they use credentials previously leaked and valid in another context. Brute force is computationally intensive and easily detected by account lockouts, while credential stuffing exploits password reuse and can be stealthier because the credentials are legitimate. Therefore, pure brute force does not describe the scenario of testing leaked passwords on multiple sites.
- *Rainbow table:* A rainbow table is a hash-cracking technique that uses precomputed tables of password hashes to reverse cryptographic hash functions. It is used when the attacker obtains password hashes and wants to discover the plaintext passwords. However, the statement describes the use of already leaked passwords (in plaintext or already cracked) to authenticate on other sites, not hash cracking. Rainbow tables do not directly apply to credential stuffing, which does not require breaking encryption but rather exploiting credential reuse.
- *Vishing:* Vishing is a form of social engineering that uses phone calls or voice messages to deceive victims and obtain confidential information, such as passwords or financial data. It does not involve automated testing of leaked credentials across multiple sites. The described scenario is clearly a technical automation attack, not a human persuasion interaction. Therefore, vishing does not apply to the context of credential stuffing, which is a mass attack based on credential lists.

2) C — Credential cloning.

✓ **Why it's correct:** The correct answer is 'Credential cloning'. Credential cloning occurs when an attacker copies the data from an access card (such as RFID badges or proximity cards) to another device, allowing unauthorized access. In the scenario, using RFID to copy the badge signal and replicate it onto a blank card is a classic example of physical credential cloning. CompTIA Security+ covers physical attacks and countermeasures, such as using encrypted cards or mutual authentication to prevent cloning.

✗ **Why the others are wrong:**

- *Tailgating:* Tailgating is the practice of physically following an authorized person through a secure door without using one's own credentials. It does not involve cloning cards or RFID; it is a passive physical intrusion. The option is incorrect because the scenario describes electronic copying of credentials, not entry by proximity.
- *Shoulder surfing:* Shoulder surfing is direct observation over someone's shoulder to obtain information such as passwords or PINs. It does not involve RFID or badge cloning. The option is incorrect because it is a visual observation technique, not electronic duplication.
- *Dumpster diving:* Dumpster diving is searching through trash for discarded information (documents, media) that could be useful to an attacker. It has no relation to RFID or credential

cloning. The option is incorrect because it involves recovering discarded data, not intercepting and copying card signals.

3) C — Implement the corresponding solution: DNS blacklist: blocks BEFORE the browser opens the site....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Web Filtering): DNS blacklist: blocks BEFORE the browser opens the site.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: Web proxy: mediates HTTP/S and can inspect....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Web Filtering): Web proxy: mediates HTTP/S and can inspect. A web proxy acts as an intermediary for HTTP/S traffic and can perform content inspection, filtering, and caching.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: 'blocks domains at the DNS level'=DNS filtering....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Web Filtering): 'blocks domains at the DNS level'=DNS filtering.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

6) B — Implement the corresponding solution: 'company blocks access to phishing sites via DNS'=DNS filtering.....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Web Filtering): 'company blocks access to phishing sites via DNS'=DNS filtering..

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

7) D — Implement the corresponding solution: DNS blocklist: blocks BEFORE the browser opens the site..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Web Filtering): DNS blocklist: blocks BEFORE the browser opens the site. DNS filtering intercepts domain name resolution requests and blocks malicious or policy-violating domains before a connection is established, providing an early preventive layer against phishing, malware, and unwanted content.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: Web proxy: mediates HTTP/S and can inspect....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Web Filtering): Web proxy: mediates HTTP/S and can inspect.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: 'blocks domains at the DNS level'=DNS filtering....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Web Filtering): 'blocks domains at the DNS level'=DNS filtering. DNS filtering blocks access to malicious or inappropriate domains by preventing their resolution, effectively enforcing web filtering policies.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) A — Implement the corresponding solution: 'company blocks access to phishing sites via DNS'=DNS filtering....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Web Filtering): 'company blocks access to phishing sites via DNS'=DNS filtering.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.